

AUDITORIA DE SISTEMAS

Governança, Riscos e Conformidade no Ciclo de Vida de TI

Material Consolidado | Sprint 1 a 6

Introdução e Escopo do Trabalho

A auditoria de sistemas é um mecanismo de governança indispensável para avaliar a **confiabilidade, segurança, disponibilidade e conformidade** dos sistemas de informação nas organizações modernas.

Objetivos Estratégicos:

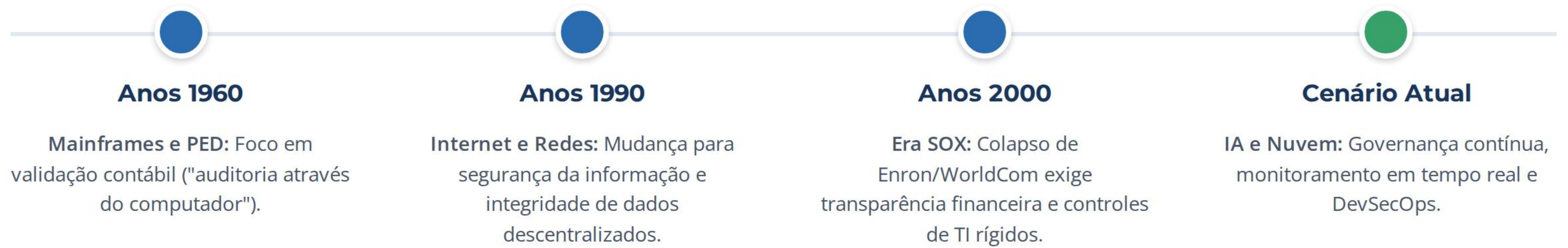
- Garantir a integridade dos dados e ativos de TI.
- Prevenir falhas, fraudes e inconsistências.
- Assegurar aderência a leis (SOX, LGPD).
- Otimizar o Ciclo de Vida de Software (SDLC).

🎯 Foco da Disciplina

Compreender os fundamentos da auditoria aplicada à TI, diferenciando as atuações interna e externa e integrando o controle ao desenvolvimento ágil moderno.

Ref: Sprint 1 [source: 3]

Evolução Histórica da Auditoria de TI



"O termo Auditor (do latim audire) remonta a 5.000 a.C., mas a tecnologia transformou o papel em consultoria estratégica de risco."

Diferenciação: Interna vs. Externa

Elemento	Auditoria Interna de TI	Auditoria Externa de TI
Vínculo	Colaborador direto ou consultor interno.	Profissional independente (terceiro).
Objetivo	Educar, mitigar riscos e melhorar processos.	Emitir parecer de fidedignidade e fé pública.
Público-Alvo	Diretoria e Conselho de Administração.	Investidores, Órgãos Reguladores e Credores.
Periodicidade	Atividade contínua e flexível.	Periódica (geralmente anual/exercício).
Normas	NBC TI 01 e IPPF (IIA).	NBC TA 200 e PCAOB.

Controles de TI: ITGC vs. ITAC

Controles Gerais (ITGC)

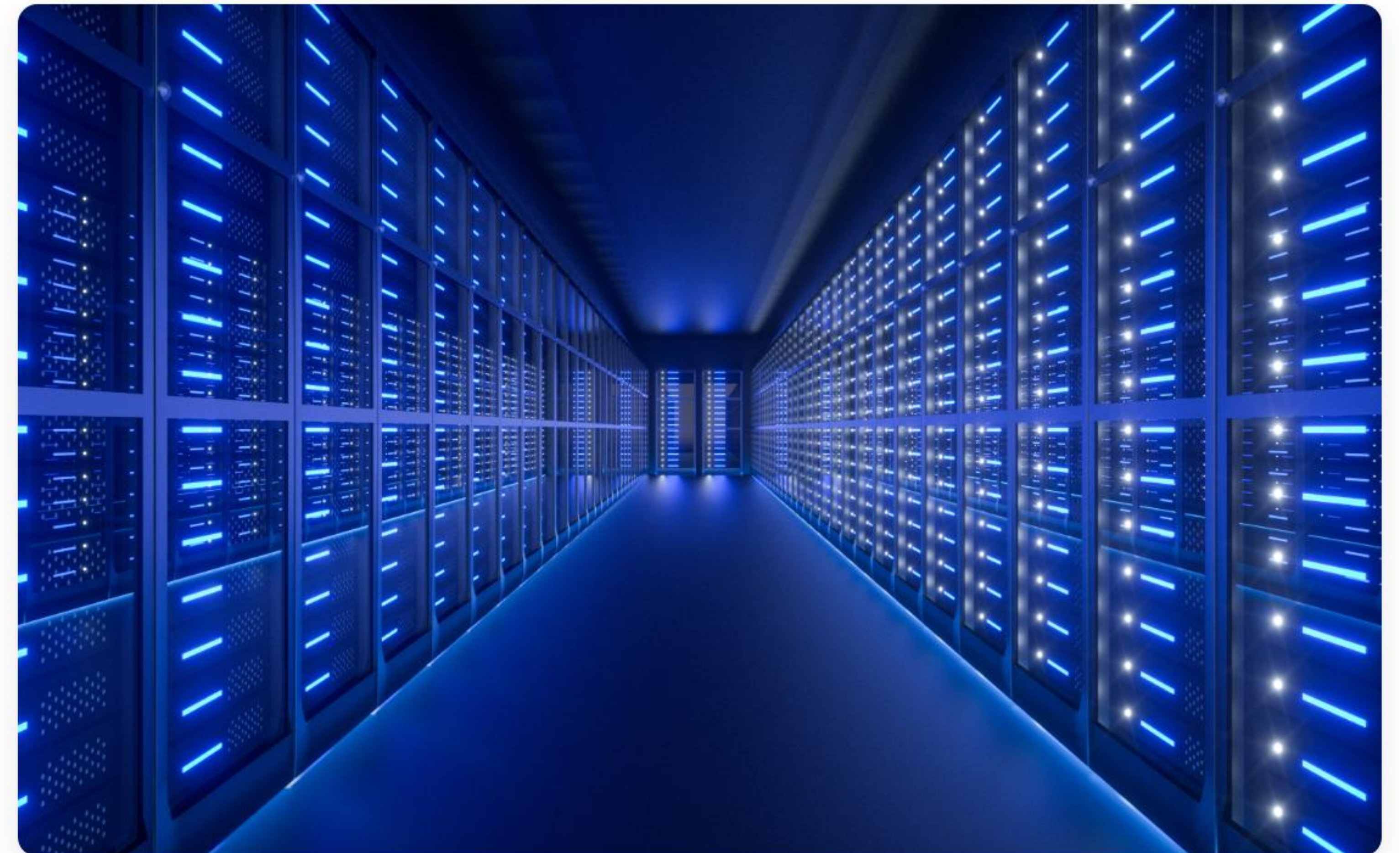
Garante estabilidade e segurança lógica e física do ambiente de dados.

- Segurança Física (Biometria/CFTV).
- Gestão de Mudanças e Backups.
- Gestão de Identidades (MFA).

Controles de Aplicação (ITAC)

Garante a integridade de transações lógicas em softwares individuais.

- Validação de Entrada (Máscaras de dados).
- Conciliação de totais e somas de controle.
- Rastreamento de logs de exportação.



Modelos Globais de Governança e Segurança



COBIT 2019

Diferencia Governança (EDM) de Gestão (APO, BAI, DSS). Focado no alinhamento estratégico e entrega de valor ao negócio.



ISO/IEC 27001

Especificações para o SGSI baseado na tríade CID. Aplica o ciclo PDCA para gerir a segurança da informação.



NIST e ITIL

O NIST foca em resiliência cibernética (Proteger/Detectar), enquanto o ITIL dita as melhores práticas operacionais de serviços.

A sinergia entre COBIT e ISO permite que a estratégia técnica atenda aos requisitos de conformidade corporativa.

Conformidade e a Lei Sarbanes-Oxley (SOX)

O Gatilho: Crises Enron e WorldCom

No início dos anos 2000, manipulações nos sistemas de informação permitiram ocultar dívidas bilionárias, destruindo a confiança no mercado.

A Resposta: Lei SOX (2002)

Reestruturou a governança de empresas listadas em bolsa (Seções 302 e 404), tornando a TI o pilar central para garantir que dados financeiros sejam **auditáveis e inalteráveis**.

Estrutura COSO

Base fundamental para o SOX, composta por 5 componentes:

- Ambiente de Controle.
- Avaliação de Riscos.
- Atividades de Controle.
- Informação e Comunicação.
- Monitoramento Contínuo.

Auditoria no Ciclo de Vida de Software (SDLC)

Fase do SDLC	Foco da Auditoria (Checkpoint)
Planejamento	Análise de custo-benefício e riscos estratégicos.
Requisitos	Definição de segurança e modelagem de ameaças.
Codificação	Revisão de código seguro (SAST) e gestão de dependências.
Testes	Testes de invasão (DAST) e aceitação de sistemas.
Implantação	Segregação de Funções (SoD) e gestão de mudanças.
Manutenção	Monitoramento de logs (SIEM) e gestão de patches.

Importante: A auditoria verifica se há evidências de cada atividade realizada ao longo do ciclo.

Auditoria e Engenharia Moderna (DevSecOps)

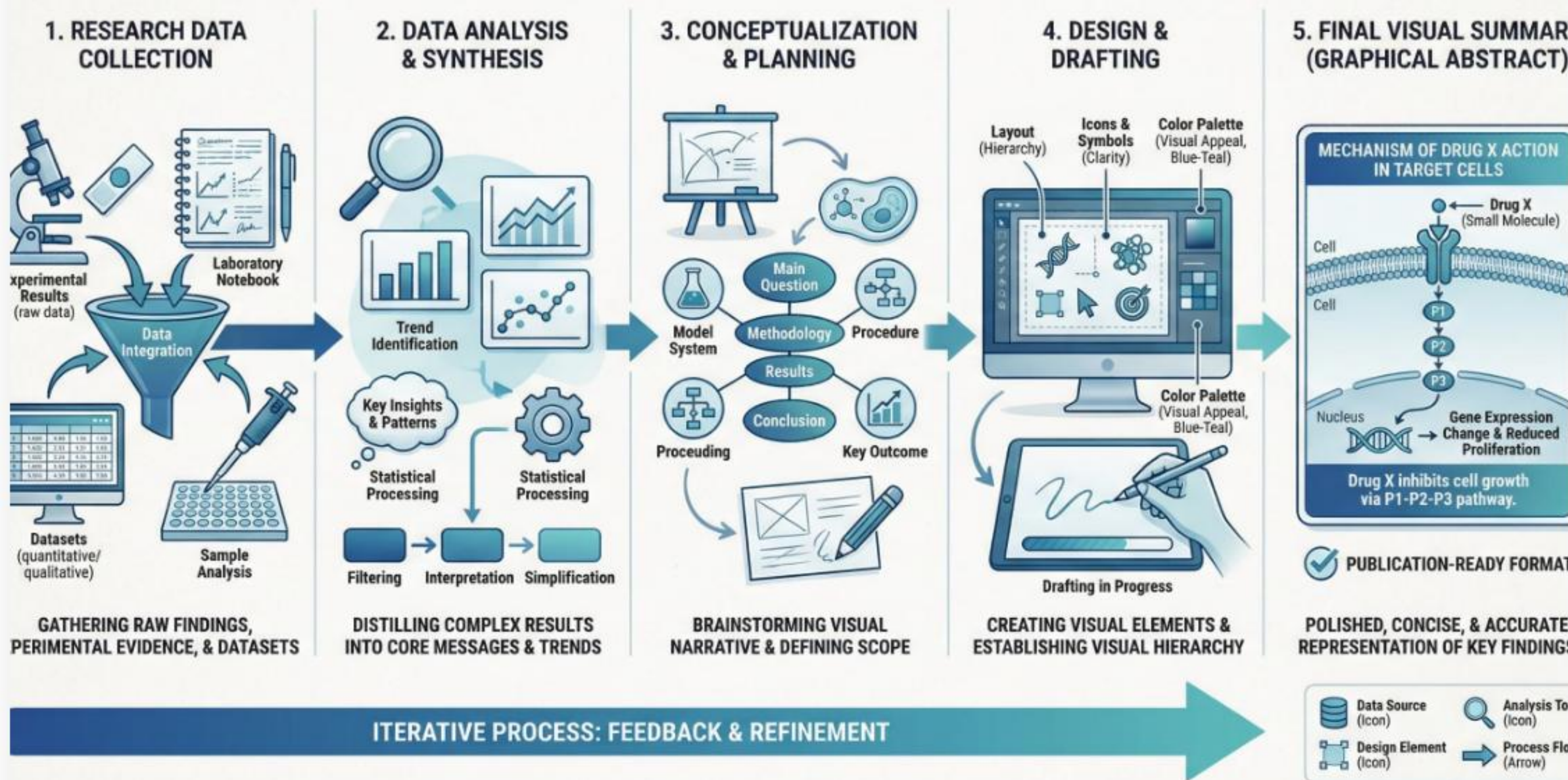
Na prática DevSecOps, a auditoria deixa de ser um evento final e passa a ser **contínua e automatizada** dentro do pipeline de CI/CD.

Fluxo Automatizado (CI/CD):

Git → Build → Testes → Verificações Seg. → Deploy

A auditoria garante que apenas código aprovado seja implantado e vulnerabilidades sejam detectadas antes da publicação.

GRAPHICAL ABSTRACT CREATION PROCESS: FROM DATA TO VISUAL SUMMARY



Maturidade de Processos: CMM e CMMI

O CMMI (Capability Maturity Model Integration) unifica modelos de engenharia para avaliar a capacidade de fornecedores e otimizar processos.

Os 5 Níveis:

5. Otimizado (Foco na melhoria)

4. Gerenciado Quantitativamente

3. Definido (Processos padronizados)

2. Gerenciado (Nível de projeto)

1. Inicial (Caótico)

Histórico:

Desenvolvido pelo SEI (Software Engineering Institute) para as Forças Armadas dos EUA, visando resolver atrasos e orçamentos estourados em encomendas de software militares.

Evolução: Do CMM (focado só em software) para o CMMI (visão integrada de sistemas).

Modelo Nacional: MPS.BR e SPICE

MPS.BR (Software Brasileiro)

Criado pela SOFTEX em 2003 para atender à realidade de micro e pequenas empresas nacionais.

Vantagem: Possui 7 níveis (A a G), permitindo uma evolução mais gradual e acessível do que o CMMI.

Baseado nas normas **ISO/IEC 12207** e no projeto **SPICE**.

Normas ISO e SPICE

O projeto **SPICE** (ISO/IEC 15504) nasceu para unificar padrões de avaliação de processos de software.

Maturidade Brasileira:

A (Excelência) → G (Parcialmente Gerenciado)

Caso 1: Fraude Fiscal e Auditoria com IA

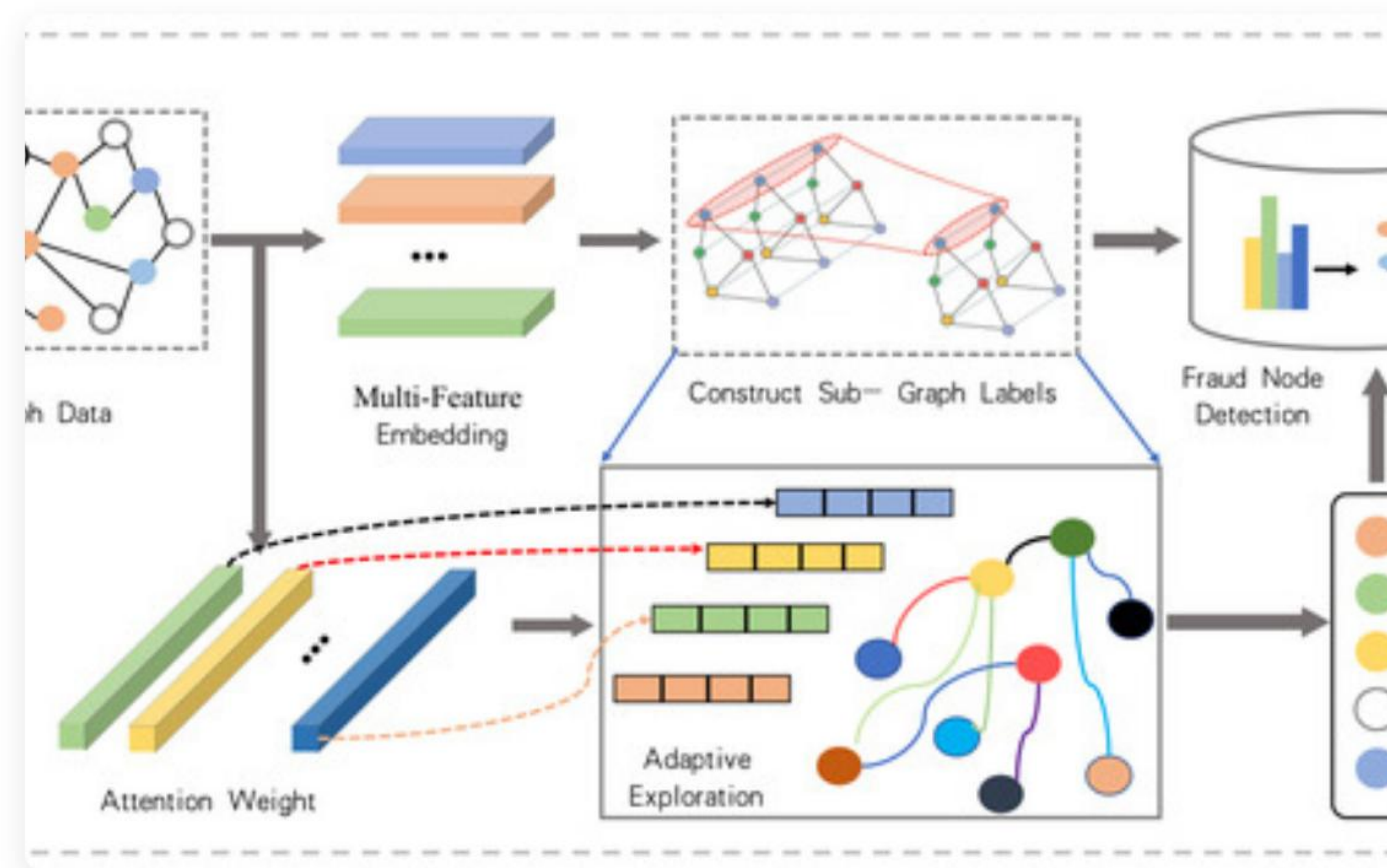
Cenário: Manipulação de Notas

Gerente financeiro de varejista adulterou registros diretamente no banco de dados para sonegar ICMS.

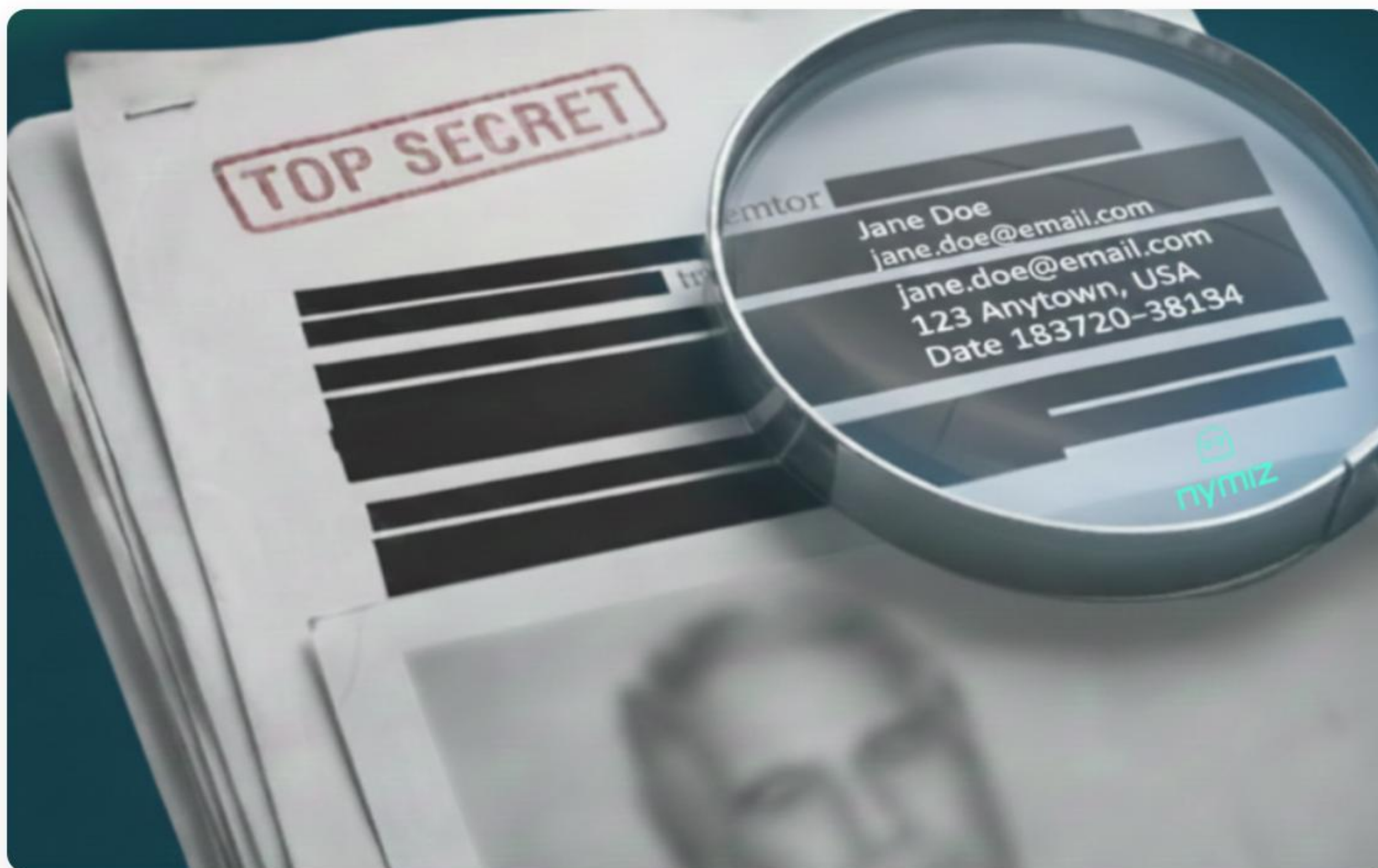
Classificação NBC TI: Fraude (intenção deliberada) e não erro operacional.

Lição Aprendida:

Sistemas SIEM estáticos falham contra fraudadores internos. A transição para IA Adaptativa permite análise comportamental contínua.



Caso 2: Riscos de Conformidade LGPD



Problema: Fragmentação de Logs

Empresa identificou eventos espalhados em firewalls, servidores e nuvem sem correlação centralizada.

Impacto LGPD:

Impossibilidade de demonstrar quem acessou dados pessoais, quando e para qual finalidade em caso de incidente.

- **Solução:** Repositório centralizado e imutável (Append-only).
- **Inventário:** Dispositivos não gerenciados são vetores críticos de vazamento.

Desafios e Limitações da Auditoria

Desafios de Implementação

- Rápida evolução (Nuvem, IoT, IA).
- Custo de ferramentas e especialistas.
- Resistência das equipes técnicas (visão punitiva).

Limitações do Processo

- Dependência de logs completos.
- Risco de amostragem inadequada.
- Auditoria periódica gera "pontos cegos".

Riscos de Não-Conformidade

- Multas regulatórias pesadas.
- Impacto jurídico e reputacional.
- Facilitação de ataques cibernéticos.

Código de Ética e Conduta do Auditor

O auditor de sistemas deve pautar-se nas diretrizes da **ISACA** para garantir isenção e prestígio à profissão:

- **Objetividade e Diligência:** Ceticismo profissional e zelo técnico.
- **Confidencialidade:** Sigilo das informações coletadas.
- **Competência:** Executar apenas tarefas para as quais possui habilitação.
- **Transparência:** Reportar fatos significativos de forma clara.

 Auditor em reunião estratégica

Conclusões Estratégicas

Auditoria = Parceria Estratégica

Adoção mandatória do modelo **Secure SDLC** para reduzir retrabalho e melhorar qualidade.

Implementação de **IA Adaptativa** para monitoramento centralizado de logs imutáveis.

Treinamento humano recorrente contra **Engenharia Social** (o elo mais fraco).

Image Sources



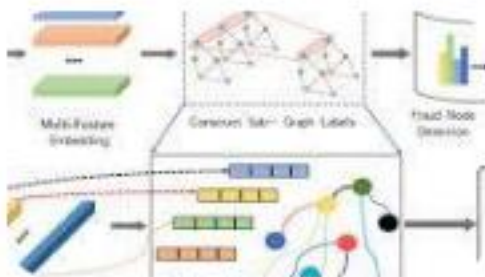
<https://dj-cnc-machining.com/wp-content/uploads/2025/05/ai-server-room-blue.jpg>

Source: dj-cnc-machining.com



https://sci-draw.com/_next/image?url=https%3A%2F%2Fpub-8c0ddfa5c0454d40822bc9944fe6f303.r2.dev%2Fimages%2Fblog%2F8c32ad8f-dade-4d7b-a065-ce8b2da0ea1f.jpg&w=3840&q=75

Source: sci-draw.com



https://www.mdpi.com/mathematics/mathematics-14-01626/article_deploy/html/images/mathematics-14-01626-g002-550.jpg

Source: www.mdpi.com



<https://www.nymiz.com/wp-content/uploads/2026/01/redact-pdf-documents-1-1024x576.png>

Source: www.nymiz.com



<https://www.nysscpa.org/cpaj-images/CPA.2023.93.11.060.uf001.jpg>

Source: www.cpajournal.com



https://png.pngtree.com/png-vector/20260113/ourlarge/pngtree-cybersecurity-alert-icon-shield-with-exclamation-mark-and-data-flow-vector-png-image_18491053.webp

Source: pngtree.com